Secretaría de Educación

DIRECCIÓN GENERAL DE UNIVERSIDADES TECNOLÓGICAS y POLITÉCNICAS

Universidad Tecnológica de Tehuacán

UNIVERSIDAD TECNOLÓGICA DE TEHUACÁN

Nombre del alumno:

Alexis Montalvo Osorio

8° "A"

Docente:

José Miguel Carrera Pacheco

Materia:

Desarrollo Web Profesional

CUATRIMESTRE ENERO-ABRIL 2026

RECUPERACIÓN DE CONTRASEÑAS ACCESIBLE Y SEGURA

Introducción

La recuperación de contraseñas es uno de los procesos más críticos dentro de cualquier sistema, ya que permite a los usuarios recuperar el acceso a sus cuentas cuando olvidan sus credenciales. Sin embargo, también es uno de los puntos más vulnerables, ya que los atacantes suelen aprovechar fallos en este flujo para obtener acceso no autorizado.

En el contexto del proyecto Urban Plus, es fundamental diseñar un proceso de recuperación que sea **seguro, accesible y fácil de usar**, garantizando tanto la protección de los datos como una experiencia adecuada para todos los usuarios.

¿Qué es un token de recuperación?

Un **token de recuperación** es un identificador único y temporal que se genera cuando un usuario solicita restablecer su contraseña. Este token se envía generalmente al correo electrónico del usuario y permite verificar que la persona que solicita el cambio tiene acceso a la cuenta asociada.

El token funciona como una especie de “llave temporal” que autoriza al usuario a crear una nueva contraseña sin necesidad de ingresar la actual.

Por ejemplo, cuando un usuario solicita recuperar su contraseña, el sistema envía un enlace a su correo. Ese enlace contiene el token, y al acceder a él, el sistema permite establecer una nueva contraseña de forma segura.

Es importante que estos tokens sean **aleatorios, únicos y difíciles de predecir**, para evitar que puedan ser utilizados por terceros.

¿Por qué deben expirar los tokens?

Los tokens de recuperación deben tener un tiempo de vida limitado para reducir riesgos de seguridad.

Si un token no expira, cualquier persona que lo obtenga podría usarlo en cualquier momento para acceder a la cuenta. Esto representa un riesgo grave, especialmente si el enlace fue interceptado o quedó almacenado en algún dispositivo.

La expiración garantiza que el token solo sea válido durante un periodo corto, por ejemplo, entre 10 y 30 minutos. Después de ese tiempo, el usuario deberá solicitar uno nuevo.

Además, los tokens deben invalidarse automáticamente una vez que se utilizan, evitando que puedan reutilizarse.

Esto asegura que el proceso de recuperación sea temporal y controlado, reduciendo significativamente las posibilidades de ataque.

¿Qué ataques existen en flujos de recuperación?

El proceso de recuperación de contraseñas es un objetivo frecuente para distintos tipos de ataques.

Uno de los más comunes es el **ataque de enumeración de usuarios**, donde el sistema revela si un correo electrónico está registrado o no. Por ejemplo, mensajes como “este correo no existe” pueden ayudar a un atacante a identificar cuentas válidas.

Otro ataque frecuente es el **phishing**, donde el atacante envía correos falsos simulando ser el sistema para engañar al usuario y obtener sus credenciales o tokens de recuperación.

También existe el **ataque de fuerza bruta**, en el cual se intentan múltiples combinaciones para adivinar tokens si estos no son suficientemente seguros.

El **robo de tokens** es otro riesgo importante. Si el token se transmite de forma insegura o se almacena incorrectamente, puede ser interceptado y utilizado por un atacante.

Finalmente, está el **reuso de tokens**, que ocurre cuando un mismo token puede ser utilizado varias veces, lo cual representa una vulnerabilidad crítica si no se invalida correctamente.

¿Cómo se diseña un flujo accesible para recuperación de acceso?

Un flujo de recuperación no solo debe ser seguro, sino también accesible para todos los usuarios, incluyendo aquellos con discapacidades.

En primer lugar, el proceso debe ser **claro y sencillo**, con instrucciones fáciles de entender. El usuario debe saber exactamente qué pasos seguir sin necesidad de conocimientos técnicos.

Los formularios deben contar con **etiquetas claras y mensajes de ayuda**, indicando qué información se requiere, como el correo electrónico.

Los mensajes de confirmación deben ser **neutrales y seguros**, por ejemplo: “Si el correo está registrado, recibirás un enlace para recuperar tu contraseña”. Esto evita revelar información sensible.

También es importante proporcionar **retroalimentación accesible**, asegurando que los mensajes puedan ser interpretados por lectores de pantalla y que sean visibles para todos los usuarios.

El flujo debe ser compatible con **navegación por teclado**, permitiendo completar el proceso sin necesidad de usar un mouse.

Además, los enlaces de recuperación deben ser fáciles de usar, evitando pasos complejos o confusos. Por ejemplo, al abrir el enlace, el usuario debe ir directamente a un formulario para crear una nueva contraseña.

Un ejemplo sencillo de flujo accesible sería:

1. El usuario ingresa su correo.
2. El sistema muestra un mensaje general sin confirmar si el correo existe.
3. El usuario recibe un enlace en su correo.
4. Al abrirlo, accede a un formulario claro para cambiar su contraseña.
5. El sistema confirma el cambio exitosamente.

¿Para qué es importante este proceso?

La recuperación de contraseñas es uno de los puntos más atacados porque permite acceder a cuentas sin necesidad de conocer la contraseña original.

Si este proceso no está bien diseñado, puede convertirse en una puerta de entrada para atacantes, comprometiendo la seguridad de los usuarios y del sistema completo.

Por otro lado, un flujo bien implementado mejora la experiencia del usuario, ya que permite recuperar el acceso de forma rápida y sin frustraciones.

Además, cumplir con buenas prácticas de seguridad y accesibilidad ayuda a generar confianza en los usuarios, lo cual es fundamental en cualquier aplicación.

Conclusión

La recuperación de contraseñas es un componente crítico que debe equilibrar seguridad y accesibilidad. El uso de tokens de recuperación permite verificar la identidad del usuario de manera temporal, pero es indispensable que estos sean seguros, únicos y con tiempo de expiración limitado.

Asimismo, es importante considerar los posibles ataques que pueden afectar este proceso, implementando medidas que reduzcan riesgos como la enumeración de usuarios, el robo de tokens o el phishing.

Por otro lado, diseñar un flujo accesible garantiza que cualquier usuario pueda recuperar su cuenta sin dificultades, independientemente de sus capacidades.

En el proyecto Urban Plus, aplicar estos principios permitirá desarrollar un sistema de recuperación robusto, seguro y centrado en el usuario, alineado con estándares profesionales y necesidades reales.